[ ] GlobiGuard

Compliance Center

What We Need to Add

March 2026 · Confidential

1. What We Already Have (and Vanta Doesn't)

Everything below is live from the demo, runtime enforcement. Vanta cannot do any of this. It is our core moat.

Capability	Status
Real-time AI action interception	**Enforced**
PII detection — 40+ field types, <3ms	**Enforced**
Policy engine — Block / Mask / Queue / Allow	**Enforced**
HIPAA enforcement (94%)	**Enforced**
HITECH enforcement (90%)	**Enforced**
42 CFR Part 2 enforcement (85%)	**Enforced**
Per-workflow compliance risk scores	**Enforced**
Full audit log — every decision, every action	**Enforced**
Human approval queue for uncertain actions	**Enforced**
Runs inside customer infrastructure (zero-knowledge)	**Enforced**

2. Compliance Frameworks to Add

We currently enforce HIPAA, HITECH, and 42 CFR Part 2 from demo. The following frameworks must be added to cover our full target market and match Vanta's 35+ framework library.

2.1 Priority — Add First

Framework	Why It Matters	Who Needs It
SOC 2 Type I & II	Security, Availability, Integrity, Confidentiality, Privacy. The #1 enterprise buyer requirement.	Every B2B prospect asks for this.
GLBA Safeguards Rule	Financial data protection. Updated 2023. Covers AI and cloud explicitly.	Accounting firms, CPA firms, insurance agencies.
GDPR	EU data protection. Fines up to 4% of global revenue. Required to sell internationally.	Any firm with EU clients.
ISO 27001	International information security standard. Required by enterprise procurement globally.	Enterprise clients worldwide.
HITRUST CSF	Combines HIPAA, NIST, ISO, PCI into one certifiable framework. Higher bar than HIPAA alone.	Healthcare vendors, fintech, pharma.
ISO 42001	The only ISO standard built specifically for AI management systems. No competitor has built runtime enforcement of it yet.	Any firm deploying AI systems. Own this first.

2.2 Full Framework Library

Framework	What It Covers	Priority
PCI DSS v4.0	Payment card data security. Mandatory for any firm handling card transactions.	**High**
CCPA / CPRA	California consumer privacy rights. Applies to any firm with California clients.	**High**

NIST CSF 2.0	Flexible cybersecurity framework. Widely used by US government and critical infrastructure.	**High**
NIST AI RMF	AI Risk Management Framework. Federal standard for AI-deploying organizations.	**High**
EU AI Act	Risk-tiered AI regulation. Classifies AI systems into prohibited, high-risk, limited, minimal.	**High**
FTC Safeguards Rule	Non-bank financial institution data protection. Tax preparers, auto dealers, mortgage firms.	**Medium**
SOX — AI Controls	Financial reporting controls. Growing applicability to AI workflows in public companies.	**Medium**
DORA	EU Digital Operational Resilience Act. Financial sector. Fully enforced 2026.	**Medium**
CMMC 2.0	Cybersecurity Maturity Model. Required for US Department of Defense contractors.	**Medium**
FERPA	Student education records protection. EdTech, universities, AI tools in education.	**Lower**
ISO 27701	Privacy Information Management System extension to ISO 27001.	**Lower**
NIST SP 800-53	Security and privacy controls for federal information systems.	**Lower**
India DPDP Act	Digital Personal Data Protection. Full compliance required May 2027.	**Future**
UAE PDPL	UAE Personal Data Protection Law. Required for Middle East market entry.	**Future**

3. Features to Add

These are the features Vanta has that we need to match — plus the AI-native features that nobody has yet.

3.1 Features Vanta Has — We Must Build

Feature	What It Does	Status
Automated evidence collection	Auto-organizes compliance proof from integrations. Required for every audit.	**Build**
Policy library	Pre-built templates: Acceptable Use, Incident Response, Data Classification, BCP, Vendor Management.	**Build**
Public Trust Center	Customer-facing page showing certifications, security posture, and compliance status. Major sales tool.	**Build**
Security questionnaire automation	AI auto-fills inbound security questionnaires (DDQs) from your knowledge base.	**Build**
Vendor / TPRM	Assess and monitor the compliance posture of third-party vendors and AI tools.	**Build**
Risk register	Centralized log of identified risks, owners, likelihood, impact, and treatment plans.	**Build**
Access management	Track which users and systems have access to what. Automate access reviews and offboarding.	**Build**
DPIA automation	Data Protection Impact Assessments required under GDPR for high-risk processing activities.	**Build**
Audit management portal	Dedicated auditor view to access evidence, review controls, and complete information requests.	**Build**

Employee security training	Assign, track, and record completion of security awareness training. Required for HIPAA.	**Build**
Record of Processing Activities	GDPR requirement. Document all data processing activities, lawful bases, and data flows.	**Build**
Multi-framework control mapping	Map one control to multiple frameworks simultaneously — avoid duplicate work across audits.	**Build**
Continuous monitoring & alerts	Real-time alerts when controls fail or compliance scores degrade. No waiting until audit time.	**Build**

3.2 AI-Native Features Nobody Has — We Can Own These

These features are exclusive to GlobiGuard because they require sitting between the AI and the data. No competitor can build them without fundamentally changing their architecture.

Feature	What It Does
ISO 42001 runtime enforcement	First platform to enforce the AI management system standard in real time — not just document it. No competitor has this.
EU AI Act workflow scoring	Automatically classify each AI workflow into EU AI Act risk tiers: prohibited, high-risk, limited, or minimal. Per-workflow, not per-organization.
NIST AI RMF live mapping	Map every blocked action to a specific NIST AI RMF control automatically. Live, auditable framework adherence.
Compliance by workflow	Show compliance score per AI workflow — not just per organization. Clinical Note Generation: 78%. Radiology AI Assist: 94%. No competitor can do this.
LLM context window enforcement	Enforce HIPAA's minimum necessary rule on every LLM context window before it is sent. Automatically strip unnecessary PHI.
Prompt injection detection	Flag and block attempts to manipulate AI agents into bypassing governance rules through adversarial inputs.
AI model version audit trail	Log which AI model version handled which data, at what time. Supports reproducibility and liability defense.

AI vendor compliance scoring	Auto-score every connected AI vendor (OpenAI, Anthropic, Google, Mistral) against customer compliance requirements in real time.
Compliance drift detection	Alert when a workflow's compliance score drops week over week. Remediate before a regulator asks.
Enforcement proof on demand	When a regulator asks 'prove your AI was HIPAA compliant on March 15th' — produce a timestamped log of every action, every block, every policy that fired on that date.
AI-specific policy templates	AI Acceptable Use Policy, LLM Data Handling Policy, AI Agent Access Control Policy, AI Incident Response Plan. Not available in any existing policy library.

4. Summary — What We Need

Category	Count to Add
Priority compliance frameworks	6 (SOC 2, GLBA, GDPR, ISO 27001, HITRUST, ISO 42001)
Full framework library	15 total frameworks (covers every regulated industry)
Vanta-parity features	14 features (evidence, policies, trust center, questionnaires, TPRM, risk register, access mgmt, DPIA, audit portal, training, ROPA, cross-mapping, monitoring)
AI-native exclusive features	12 features (no competitor can replicate these)

Vanta proves a policy exists. GlobiGuard proves it was enforced — on every AI action, in real time, with a timestamped record nobody can dispute.

GlobiGuard · globiguard.com · support@globiguard.com

Confidential — March 2026